

Security+ 5.5 · Penetration Tests

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 5.5** —
Penetration Tests (5:29) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Penetration testing complements auditing by providing evidence of real exploitation. Perspectives include external, internal, and fully trusted (with credentials). Techniques include reconnaissance, OSINT, and social engineering. Responsible disclosure is expected. Pentests are more technical and less formal than audits.

High-Yield Core Concepts Tested on Exam

- Pentest: provides evidence of real exploitation — complements formal audit
- Perspectives: external (from outside), internal (from inside), full credentials (fully trusted)
- Techniques: reconnaissance, OSINT, social engineering
- Responsible disclosure of findings

Exam Tips & Classic Scenarios

- 'external perspective attempting to exploit from outside' = external pentest
- If they hire a pentester to try to break in from outside, it's an external pentest

Typical Exam Scenario: A company hires a penetration tester to attempt to breach the network from outside. This is an external penetration test.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 5.5 — Penetration Tests)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Corporate scenario (Penetration Tests): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'Pentest: EVIDENCES real exploitation — complements formal audit'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Pentest: EVIDENCES real exploitation — complements formal audit...
- D)** Allow shared access among administrators with generic credentials

2. Corporate scenario (Penetration Tests): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'Perspectives: external (from outside), internal (from inside), full credential.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Perspectives: external (from outside), internal (from inside), full credential...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

3. Corporate scenario (Penetration Tests): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'external perspective attempting to exploit from outside'=external pentest'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'external perspective attempting to exploit from outside'=external pentest...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (Penetration Tests): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'they hire a pentester to try to break in from outside'=external pentest.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'they hire a pentester to try to break in from outside'=external pentest...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Penetration Tests): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'Pentest: EVIDENCES real exploitation — complements formal audit'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Pentest: EVIDENCES real exploitation — complements formal audit...
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Penetration Tests): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'Perspectives: external (from outside), internal (from inside), full credential'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Perspectives: external (from outside), internal (from inside), full credential...

7. Corporate scenario (Penetration Tests): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'external perspective attempting to exploit from outside = external pentest.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'external perspective attempting to exploit from outside' = external pentest...

8. Corporate scenario (Penetration Tests): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'they hire a pentester to try to break in from outside' = external pentest. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'they hire a pentester to try to break in from outside' = external pentest.

9. Corporate scenario (Penetration Tests): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'Pentest: EVIDENCES real exploitation — complements formal audit.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Pentest: EVIDENCES real exploitation — complements formal audit...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Penetration Tests): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'Perspectives: external (from outside), internal (from inside), full credential'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Perspectives: external (from outside), internal (from inside), full credential
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) C — Implement the corresponding solution: Pentest: EVIDENCES real exploitation — complements formal audit....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Penetration Tests): Pentest: EVIDENCES real exploitation — complements formal audit.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

2) B — Implement the corresponding solution: Perspectives: external (from outside), internal (from inside), full credential....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Penetration Tests): Perspectives: external (from outside), internal (from inside), full credential. These perspectives define the vantage point of the penetration test: external testing simulates an outside attacker, internal testing simulates an insider threat or compromised internal host, and full credential testing uses valid credentials to assess what an authenticated user can access. Understanding these perspectives is essential for scoping and interpreting penetration test results.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

3) B — Implement the corresponding solution: 'external perspective attempting to exploit from outside'=external pentest....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Penetration Tests): 'external perspective attempting to exploit from outside'=external pentest.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are

administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: 'they hire a pentester to try to break in from outside'=external pentest....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Penetration Tests): An external penetration test involves hiring a pentester to attempt to breach the organization's perimeter from outside, simulating an external attacker's perspective.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) C — Implement the corresponding solution: Pentest: EVIDENCES real exploitation — complements formal audit....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Penetration Tests): Pentest: EVIDENCES real exploitation — complements formal audit. A penetration test actively exploits vulnerabilities to demonstrate real-world impact, providing evidence that complements a formal audit, which typically checks compliance rather than exploitation.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: Perspectives: external (from outside), internal (from inside), full credential....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Penetration Tests): Perspectives: external (from outside), internal (from inside), full credential.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

7) D — Implement the corresponding solution: 'external perspective attempting to exploit from outside' = external pentest....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Penetration Tests): An external penetration test simulates an attacker from outside the organization's network perimeter, attempting to exploit externally exposed assets. It differs from internal, blind, or double-blind tests.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: 'they hire a pentester to try to break in from outside' = external pentest..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Penetration Tests): 'they hire a pentester to try to break in from outside' = external pentest. An external penetration test is a sanctioned, scoped attack simulation conducted from outside the organization's perimeter to identify exploitable vulnerabilities in internet-facing assets before real adversaries do.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) A — Implement the corresponding solution: Pentest: EVIDENCES real exploitation — complements formal audit....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Penetration Tests): Penetration testing provides evidence of real exploitation attempts, complementing formal audits by demonstrating actual security weaknesses through controlled attacks.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: Perspectives: external (from outside), internal (from inside), full credential.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Penetration Tests): Perspectives: external (from outside), internal (from inside), full credential. These perspectives define the attacker's starting point and access level during a penetration test.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.